

Reporte Ejecutivo de Riesgos

Clínica privada - Trabajo práctico con SimpleRisk

Alumna	Micaela Chacón
LU	31394604
Escenario	Clínica privada - 120 empleados - 800 pacientes por día

1. Resumen ejecutivo

El análisis identificó siete riesgos vinculados con la confidencialidad, integridad y disponibilidad de la información utilizada por la clínica. La evaluación se realizó con la matriz de Probabilidad por Impacto definida por la cátedra, en una escala de 1 a 5.

El resultado inicial muestra una exposición elevada: seis riesgos quedaron clasificados como Críticos y uno como Alto. Las prioridades se concentran en ransomware, recuperación de información, continuidad del sistema clínico, accesos no autorizados y filtración de datos sensibles.

La clínica del caso maneja historias clínicas digitales, datos de obras sociales y facturación. La consigna también informa que una auditoría externa detectó debilidades en la gestión de riesgos.

2. Top 5 de riesgos

ID	Riesgo	P	I	P x I	Nivel
R02	Ransomware sobre historias clínicas digitales	4	5	20	Crítico
R04	Falla o pérdida de copias de seguridad	4	5	20	Crítico
R05	Caída del sistema de gestión clínica	4	5	20	Crítico
R08	Filtración de datos de pacientes y obras sociales	4	5	20	Crítico
R03	Acceso no autorizado a historias clínicas	4	4	16	Crítico

Nota: R06 - Phishing también obtuvo 16 puntos y nivel Crítico. Para el Top 5 se priorizó R03 por su relación directa con el acceso a historias clínicas.

3. Estado de los planes de acción

Plan	Riesgo	Objetivo	Vencimiento	Responsable	Estado
PA01	R02	Reducir la exposición frente a ransomware y mejorar la recuperación	05/10/2026	Analista de Riesgos	0 %
PA02	R04	Fortalecer los respaldos y verificar la recuperación	15/10/2026	Analista de Riesgos	0 %
PA03	R05	Mejorar la continuidad y recuperación del sistema clínico	20/10/2026	Analista de Riesgos	0 %

En los tres planes se configuró el rango presupuestario \$0 - \$100.000 dentro de SimpleRisk. La moneda no se especifica en el registro utilizado, por lo que se conserva únicamente el rango mostrado por la herramienta.

4. Recomendaciones prioritarias

Prioridad	Tema	Recomendación
1.	Ransomware y recuperación	Fortalecer la protección de los equipos, mantener los sistemas actualizados, proteger las copias de seguridad y realizar pruebas de restauración.
2.	Accesos	Incorporar autenticación multifactor, revisar permisos y aplicar el principio de mínimo privilegio.
3.	Continuidad	Implementar monitoreo de disponibilidad, procedimientos de contingencia y mecanismos de redundancia para los componentes críticos.
4.	Personas	Capacitar al personal para reconocer intentos de phishing y establecer un mecanismo simple para reportar mensajes sospechosos.
5.	Información sensible	Mantener trazabilidad sobre cambios en información médica y monitorear los accesos a datos sensibles.

5. Amenaza externa y defensa en profundidad

Como analogía de amenaza externa, el Lobo Feroz representa a un actor que intenta aprovechar una debilidad para alcanzar a Caperucita Roja. Trasladado al escenario de la clínica, una amenaza externa puede buscar acceder a información sensible o interrumpir los servicios digitales.

El tratamiento debe basarse en defensa en profundidad. La analogía de los Tres Cerditos permite representar esta idea: no depender de una sola barrera, sino combinar controles de acceso, protección de equipos, copias de seguridad, capacitación, monitoreo y procedimientos de recuperación.

6. Riesgo residual proyectado

El riesgo residual es una estimación realizada para el ejercicio y representa cómo podría quedar cada riesgo después de implementar correctamente las salvaguardas propuestas. No describe el estado actual de la clínica.

Riesgo	P residual	I residual	Valor	Nivel
R02 - Ransomware	2	4	8	Medio
R03 - Acceso no autorizado	2	4	8	Medio
R04 - Copias de seguridad	2	4	8	Medio
R05 - Caída del sistema	2	4	8	Medio
R06 - Phishing	2	4	8	Medio
R07 - Modificación de información médica	2	5	10	Alto
R08 - Filtración de datos	2	5	10	Alto

7. Recomendación física prioritaria

Como criterio de protección física, los centros de datos no deberían ubicarse al lado de cocinas ni debajo de piletas. La cercanía a una cocina aumenta la exposición ante incendios y una ubicación debajo de una pileta aumenta la exposición ante filtraciones o inundaciones. Estas condiciones deben evitarse al definir la ubicación de infraestructura crítica.

8. Conclusión para el directorio

El registro inicial permite observar que los riesgos más relevantes combinan una probabilidad significativa con consecuencias severas sobre la atención y la información de los pacientes. La prioridad debería estar en reducir la posibilidad de ransomware y accesos indebidos, asegurar la capacidad de recuperación y mejorar la continuidad del sistema clínico.

Las medidas propuestas no eliminan por completo el riesgo, pero permiten disminuir la exposición y establecer una base más sólida para una gestión de riesgos continua. Se recomienda revisar periódicamente el registro, actualizar los controles implementados y reevaluar el riesgo residual después de verificar su eficacia.

9. Síntesis

Riesgos del escenario	7
Riesgos críticos iniciales	6
Riesgos altos iniciales	1
Planes de mitigación configurados	3
Prioridad inmediata	Ransomware, backups, continuidad, accesos y datos sensibles